



第一章 数据安全概述

目 录

「01」

知识点一：法规制度

「02」

知识点二：技术体系

「03」

知识点三：典型案例

「04」

知识点四：数据胶囊

引言



网络空间安全对抗的实质：保护服务和数据

- ✓ 服务：保护网络服务不遭破坏，可正常服务
- ✓ 数据：保护隐私数据不被窃取

服务和数据的对抗博弈一直存在，而且会永远持续下去

引言

总体国家安全观 学习纲要

中共中央宣传部
中央国家安全委员会办公室

学习出版社
人民出版社

2022年,《总体国家安全观学习纲要》将国家安全的内涵进行了扩充,从16个领域扩展到20个领域,其中增加了数据安全的内容。强调:当前数据安全问题比较突出,绝不能掉以轻心。浩瀚的数据海洋就如同工业社会的石油资源,蕴含着巨大生产力和商机,谁掌握了大数据,谁就掌握了发展的资源和主动权。要把握好大数据发展的重要机遇,促进大数据产业健康发展,处理好数据安全、网络空间治理等方面的挑战。

数据安全已纳入国家安全内容

引言

数字经济是世界经济发展的重要方向，全世界都在出台法律法规对数据安全提出要求和约束



中华人民共和国
网络安全法

2017年6月实施

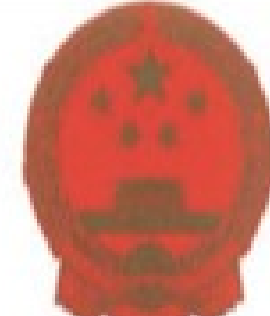


2018年5月实施



中华人民共和国
密码法

2020年5月实施



中华人民共和国
数据安全法

2021年9月实施



中华人民共和国
个人信息保护法

2021年11月实施

保护数据不被窃取和滥用，实现数据的安全共享和流通，成为推动数字经济发展和科技创新、保障国家数据安全的关键问题。

1. 数据安全法

共包含7章，从数据安全与发展、数据安全制度、数据安全保护义务、政务数据安全和开放、法律责任等方面给出明确规定

(1) 数据安全相关定义

数据

是指任何以电子或者其他方式对信息的记录。

数据处理

包括数据的收集、存储、使用、加工、传输、提供、公开等。

数据安全

是指通过采取必要措施，确保数据处于**有效保护**和**合法利用**的状态，以及具备保障持续安全状态的能力。



中华人民共和国
数据安全法

1. 数据安全法

(2) 数据安全与发展：在第十三条指出“国家统筹发展和安全，坚持以数据开发利用和产业发展促进数据安全，以数据安全保障数据开发利用和产业发展。”同时，规定：

第十六条 国家支持数据开发利用和数据安全技术研究，鼓励数据开发利用和数据安全等领域的技术推广和商业创新，培育、发展数据开发利用和数据安全产品、产业体系。

第十七条 国家推进数据开发利用技术和数据安全标准体系建设。国务院标准化行政主管部门和国务院有关部门根据各自的职责，组织制定并适时修订有关数据开发利用技术、产品和数据安全相关标准。国家支持企业、社会团体和教育、科研机构等参与标准制定。

第十八条 国家促进数据安全检测评估、认证等服务的发展，支持数据安全检测评估、认证等专业机构依法开展服务活动。国家支持有关部门、行业组织、企业、教育和科研机构、有关专业机构等在数据安全风险评估、防范、处置等方面开展协作。

第十九条 国家建立健全数据交易管理制度，规范数据交易行为，培育数据交易市场。

截止到2023年底，数据安全检测评估尚未完全普及，数据交易市场尚未形成规模，还有很长的路要走。

1. 数据安全法

(3) 数据安全制度：数据安全法明确了6项数据安全制度：

- **数据分类分级与核心数据保护制度**（第二十一条）。确立了依据对国家安全、公共利益或者个人、组织合法权益造成的危害程度进行分类分级的原则.....
- **数据安全风险评估与工作协调机制**（第二十二条）。
- **数据安全应急处置机制**（第二十三条）。要求对于发生数据安全事件的，主管部门应当依法启动应急预案，采取相应的应急处置措施，防止危害扩大，消除安全隐患。
- **数据安全审查制度**（第二十四条）。要求对影响或者可能影响国家安全的数据处理活动进行国家安全审查。
- **数据出口管制制度**（第二十五条）。要求对与维护国家安全和利益、履行国际义务相关的属于管制物项的数据依法实施出口管制。
- **歧视反制制度**（第二十六条）。规定对我国采取相关歧视性的禁止、限制或者其他类似措施的国家 and 地区，我国可以对其采取对等措施。

目前，这些制度正处于推动落实的阶段，距离全面普及实施还有很长一段距离。

2. 个人信息保护法

共计八章七十条，围绕个人信息的处理，从处理规则、跨境提供、个人权利处理者义务、保护职责部门以及法律责任等不同角度确立了相应规则，并且针对敏感个人信息和国家机关处理强调了特别规则

(1) 个人信息相关定义

个人信息

是以电子或者其他方式记录的与已识别或者可识别的自然人有关的各种信息，不包括匿名化处理后的信息。

个人信息的处理

包括个人信息的收集、存储、使用、加工、传输、提供、公开、删除等。



中华人民共和国
个人信息保护法

2. 个人信息保护法

(2) 个人信息的处理规则

以“告知-知情-同意”为核心的个人信息处理规则：

- 处理个人信息应当具有明确、合理的目的，并应当与处理目的直接相关，采取对个人权益影响最小的方式。收集个人信息，应当限于实现处理目的的最小范围。
- 处理个人信息应当在事先充分告知的前提下取得个人同意，个人信息处理的重要事项发生变更的应当重新向个人告知并取得同意。

2. 个人信息保护法

(3) 严格限制处理敏感个人信息

- **个人信息保护法规定，敏感个人信息包括生物识别、宗教信仰、特定身份、医疗健康、金融账户、行踪轨迹等信息，以及不满十四周岁未成年人的个人信息。**
- 处理敏感个人信息比处理一般个人信息更为严格，只有在具有特定目的和充分的必要性，并采取严格保护措施的情形下，取得个人单独或书面同意才能进行。

2. 个人信息保护法

(4) 规范个人信息跨境处理

个人信息保护法规定，个人信息处理者因业务等需要，需向境外提供个人信息的：

- **应当通过国家网信部门组织的安全评估**
- 按照国家网信部门的规定经专业机构**进行个人信息保护认证**
- 按照国家网信部门制定的标准合同与境外接收方订立合同，约定双方的权利和义务
- 符合法律、行政法规或者国家网信部门规定的其他条件
- 采取必要措施，保障境外接收方处理个人信息的活动达到本法规定的个人信息保护标准

2. 个人信息保护法

(5) 明确大型互联网平台个人信息保护义务

个人信息保护法对大型互联网平台设定特别的个人信息保护义务，包括：

- 按照国家规定建立健全个人信息保护合规制度体系，成立主要由外部成员组成的独立机构对个人信息保护情况进行监督
- 遵循公开、公平、公正的原则，制定平台规则
- **对严重违法处理个人信息的平台内产品或者服务提供者，停止提供服务**
- 定期发布个人信息保护社会责任报告，接受社会监督

下列说法正确的是

- A 不满十四周岁未成年人的姓名、身高等个人信息不属于敏感信息
- B 经过匿名化处理后的信息，不再属于个人信息
- C 数据安全法的出台是为了加强数据安全管控，是以牺牲发展代价的
- D 数据安全是指通过采取必要措施，确保数据处于有效保护的状态

3. 相关权益

《个人信息保护法》规定个人在个人信息处理活动中的七项权利：

- **知情同意权**：收集和使用公民个人信息必须遵循合法、正当、必要原则，且目的必须明确并经用户的知情同意；
- **决定权**：有权限制、拒绝或撤回他人对其个人信息的处理；
- **查阅复制权**：个人有权向个人信息处理者查阅、复制其个人信息；
- **个人信息移转权**：个人请求将个人信息转移至其指定的个人信息处理者，符合国家网信部门规定条件的，个人信息处理者应当提供转移的途径；
- **更正补充权**：个人发现其个人信息不准确或者不完整的，有权请求个人信息处理者更正、补充；

3. 相关权益

《个人信息保护法》规定个人在个人信息处理活动中的七项权利：

□ **删除权**：在五种情形下，个人信息处理者应当主动删除个人信息；个人信息处理者未删除的，个人有权请求删除：

- 处理目的已实现、无法实现或者为实现处理目的不再必要，
- 个人信息处理者停止提供产品或者服务，或者保存期限已届满，
- 个人撤回同意，
- 个人信息处理者违反法律、行政法规或者违反约定处理个人信息，
- 法律、行政法规规定的其他情形；

□ **规则解释权**：个人有权要求个人信息处理者对其个人信息处理规则进行解释说明。

3. 相关权益

欧盟GDPR定义了多种用户权益：

Transparency & Auditing 透明&审计

数据主体应当知道谁拥有他们的数据&数据是如何处理的。 (Article 13-14)

知情权

Consent 同意

数据主体应该明确同意收集、处理他们的数据。 (Article 4、7)

决定权

Processing Control 处理控制

数据主体应该有权控制对他们的数据应用的处理类型。 (Article 18、22)

决定权

Data Portability 数据携带权

数据主体应该能够获得与他们相关的任何数据的副本。 (Article 15-17、20)

查阅复制权

3. 相关权益

GDPR还定义了删除权、被遗忘权等多种权益。

删除权与被遗忘权是有区别的：

- 简单来说，**传统的删除权是一对一的**，即用户个人（数据主体）对于企业（数据控制者）提出的要求，当数据主体认为数据控制者违法或违约收集、使用其个人信息的情况下，有权要求企业删除其个人数据。
- 而GDPR在传统删除权上进一步扩展提出的“**被遗忘权**”是一对多的，**不仅包含传统的删除权的权利要求，还包括要求数据控制者负责将其已经扩散出去的个人数据，采取必要的措施予以消除。**

4. 落地实施

《网络数据安全管理条例》：是在《中华人民共和国网络安全法》《中华人民共和国数据安全法》《中华人民共和国个人信息保护法》三部上位法的基础上制定，在实施细则、责任界定、规范要求、惩罚措施等方面更加清晰细致，同时增加了一些新的内容，进一步强化和落实数据处理者的主体责任，共同保护重要数据和个人信息的安全。

(1) 主体定义

数据处理者：在数据处理活动中自主决定处理目的和方式的个人和组织。

互联网平台运营者：为用户提供信息发布、社交、交易、支付、视听等互联网平台服务的数据处理者。

大型互联网平台运营者：用户超过五千万、处理大量个人信息和重要数据、具有强大社会动员能力和市场支配地位的互联网平台运营者。

4. 落地实施

(2) 明确数据分类分级标准

《条例》第五条指出，国家需建立数据分类分级保护制度。

数据分类是按照数据具有的某种共同属性或特征（包括数据对象共享属性、开放属性、应用场景等），采用一定原则和方法进行区分和归类，以便于管理和使用数据。

数据分级目的是差异化保护数据安全，按照数据遭到破坏（包括攻击、泄露、篡改、非法使用等）后对国家安全、社会稳定、公共利益以及个人、法人和其他组织的合法权益（受侵害客体）的危害程度对数据进行定级，为数据全生命周期管理的安全策略制定提供支撑。

4. 落地实施

按照数据对国家安全、公共利益或者个人、组织合法权益的影响和重要程度，将数据分为一般数据、重要数据、核心数据，不同级别的数据应采取不同的保护措施：

- **核心数据：**对领域、群体、区域具有较高覆盖度或达到较高精度、较大规模、一定深度的重要数据，一旦被非法使用或共享，可能直接影响政治安全。主要包括关系国家安全重点领域的数据，关系国民经济命脉、重要民生、重大公共利益的数据，经国家有关部门评估确定的其他数据。
- **重要数据：**特定领域、特定群体、特定区域或达到一定精度和规模的数据，一旦被泄露或篡改、损毁，可能直接危害国家安全、经济运行、社会稳定、公共健康和安全等的数据。仅影响组织自身或公民个体的数据，一般不作为重要数据。
- **一般数据：**核心数据、重要数据之外的其他数据。

4. 落地实施

数据分类分级是企业数据安全治理的基础环节，也是国家、政府平衡数据保护与数据流通的重要手段，通过对敏感数据的分级，提升数据的安全性，降低企业的合规性风险。任何时候，数据的定级都离不开数据的分类。因此，在数据安全治理或数据资产管理领域都是将数据的分类和分级放在一起，统称为数据分类分级。

目前，诸如金融、工业、电信、医疗和汽车等行业均已出台了针对性的数据分类分级指南或技术规范，天津市自贸港也率先推出了涉及数据出境相关的重要数据分类指南。

分类分级标准/指南	发布组织	发布时间
GB/T 35273 2020 信息安全技术 个人信息安全规范	国家市场监督管理总局 国家标准化管理委员会	2020-03-06
GB/T 38667 2020 信息技术 大数据 数据分类指南	国家市场监督管理总局 国家标准化管理委员会	2020-04-28
GB/T 39725-2020 信息安全计算 健康医疗数据安全指南	国家市场监督管理总局 国家标准化管理委员会	2020-12-14
TC260-PG-20212A 网络安全标准实践指南-网络数据分类分级指引	全国信息安全标准化计 算委员会秘书处	2021-12-31

4. 落地实施

(3) 其他相关规定

《条例》还从多个方面给出规定，比如**规定重要数据需落实等保等**。《条例》第九条指出，数据处理者应当按照网络安全等级保护的要求，加强数据处理系统、数据传输网络、数据存储环境等安全防护，处理重要数据的系统原则上应当满足三级以上网络安全等级保护和关键信息基础设施安全保护要求，处理核心数据的系统依照有关规定从严保护。

总体上，目前技术保障、落地实施等方面，距离实现数据全生命周期的安全防护、全面落实《数据安全法》和《个人信息保护法》还有很长的路要走。

要求数据控制者负责将其已经扩散出去的个人数据，采取必要的措施予以消除的相关权益是

- ☐ A 删除权
- ☐ B 被遗忘权
- ☐ C 知情权
- ☐ D 查阅复制权

目 录

「01」

知识点一：法规制度

「02」

知识点二：技术体系

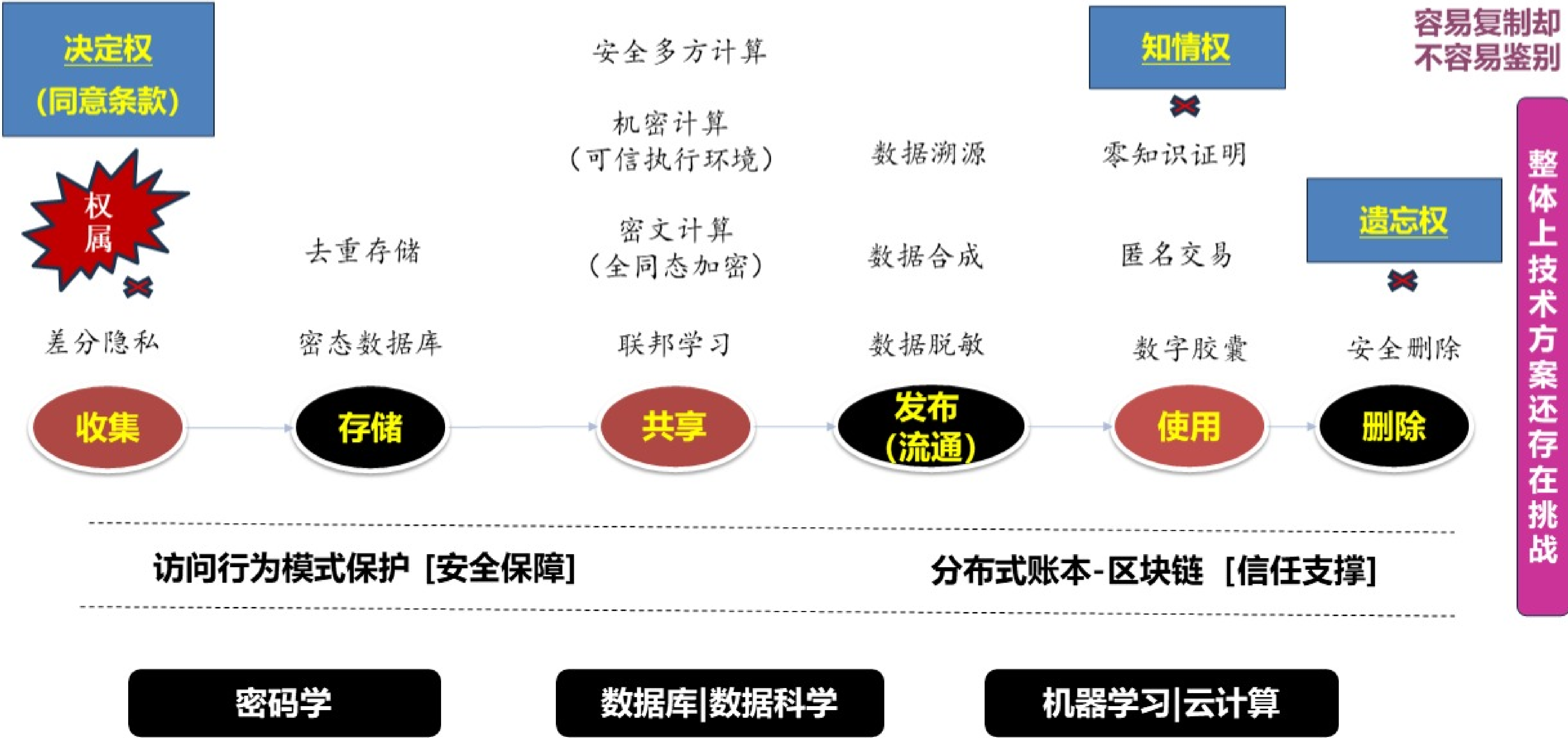
「03」

知识点三：典型案例

「04」

知识点四：数据胶囊

1. 技术体系



2. 密码概念

- ❑ 密码技术的基本思想是伪装信息，所谓伪装就是对数据进行一组可逆的数学变换。伪装前的原始数据称为明文（Plaintext），而伪装后的消息称为密文（Ciphertext）。
- ❑ 伪装的数据变换过程称为加密（Encryption），相反的，将密文还原成明文的过程称为解密（Decryption）。
- ❑ 加密和解密算法的操作通常都是在一组密钥的控制下进行的，分别称为加密密钥（Encryption Key）和解密密钥（Decryption Key），加密密钥通常用 K_e 来表示，解密密钥通常用 K_d 来表示。

2. 密码概念

一个密码系统（即密码体制），通常由五部分组成：

▣消息空间：所有可能明文 m 的有限集称为明文空间，通常用 M 表示；

▣密文空间：所有可能密文 c 的有限集称为密文空间，通常用 C 表示；

▣密钥空间：一切可能的密钥 k 构成的有限集称为密钥空间，通常用 K 表示；

▣加密算法：加密算法是基于密钥 k 将明文 m 变换为密文 c 的变换函数，相应的变换过程称为加密，通常用 E 表示，即 $c=E_k(m)$ ，也可表示为 $c=E(m, k)$ 。

▣解密算法：解密算法是基于密钥 k 将密文 c 恢复为明文 m 的变换函数，相应的变换过程称为解密，通常用 D 表示，即 $m=D_k(c)$ ，也可表示为 $m=D(c, k)$ 。

2. 密码概念

- 根据密钥的数量，可以将密码体制分为两类：**对称密钥密码体制**和**非对称密钥密码体制**。
- 如果一个密码体制的 $K_d=K_e$ ，即发送方和接收方双方使用的密钥相同，则称为对称密钥密码体制；相反地，如果 $K_d \neq K_e$ ，即发送方和接收方双方使用的密钥不相同，则称为非对称密钥密码体制。
- 在非对称密钥体制中，由于在计算上 K_d 不能由 K_e 推出，这样将 K_e 公开也不会损害 K_d 的安全，于是可以将 K_e 公开，因此，这种密码体制又被称为公开密钥密码体制。公开密钥密码体制的概念，由Diffie和Hellman于1976年提出，它的出现是密码史上的一个里程碑。

3. 哈希函数

- ❑ 哈希（hash）函数又称为散列函数、杂凑函数，它是一种单向密码体制，即它是一个从明文到密文的不可逆映射，只有加密过程，没有解密过程。
- ❑ 哈希函数可以将任意长度的输入经过变换后得到固定长度的输出。这个固定长度的输出称为原消息的“散列”或“消息摘要”（Message Digest）。哈希函数的数学表述为：

$$h = H(m)$$

其中 $H()$ 是哈希函数， m 是任意长度明文， h 是固定长度的哈希值。

3. 哈希函数

- ▣ 理想的哈希函数对于不同的输入，获得的哈希值不同。如果存在 x 、 x' 两个不同的消息，存在 $H(x) = H(x')$ ，则称 x 和 x' 是哈希函数 H 的一个碰撞。
- ▣ 哈希函数的这种单向的特性以及长度固定的特征使得它可以生成消息或者数据块的“消息摘要”（也称为散列值、哈希值），因此，在数据完整性和数字签名领域有着广泛的应用。
- ▣ 典型的哈希函数有：消息摘要算法MD5（Message Digest Algorithm）和安全散列算法SHA（Secure Hash Algorithm）。

3. 哈希函数

哈希算法有一些特点：

- ①压缩。对于任意大小的输入 x ，哈希值 $H(x)$ 的长度很小，实际应用中哈希函数 H 产生的哈希值是固定长度的。
- ②易计算。对于任意给定的消息，容易计算其哈希值。
- ③单向性。对于给定的哈希值 h ，要找到 m' 使得 $H(m') = h$ 在计算上是不可行的，即求哈希函数的逆很困难。
- ④抗碰撞性。理想的哈希函数是无碰撞的，但实际算法设计中很难做到。因此有两种抗碰撞性：一种是弱抗碰撞性，即对于给定的消息 x ，要发现另一个消息 y ，满足 $H(x) = H(y)$ 在计算上不可行；一种是强抗碰撞性，即对任意一对不同的消息 (x, y) ，使得 $H(x) = H(y)$ 在计算上不可行。
- ⑤高灵敏性。当一个输入位发生变化时，输出位将有一半以上会发生变化。

3. 哈希函数

- ❑ **消息认证：** 在一个开放通信网络的环境中，信息面临的攻击包括窃听、伪造、修改、插入、删除、否认等。因此，需要提供用来验证消息完整性的一种机制或服务，即消息认证。这种服务的主要功能包括确保收到的消息确实和发送的一样、确保消息的来源真实有效等，用于消息认证的最常见的密码技术是基于哈希函数的消息认证码。
- ❑ **数字签名：** 由于非对称算法的运算速度较慢，所以在数字签名协议中，哈希函数扮演了一个重要的角色。对哈希，又称“消息摘要”进行数字签名，在统计上可以认为与对文件本身进行数字签名是等效的。

3. 哈希函数

❑ **口令的安全性：** 由于哈希函数具有单向性的特征，在口令保护中应用非常广泛。通常，口令仅仅将其哈希值进行保存，进行口令校验的时候比对哈希值即可，即使攻击者获得了保存的哈希值，也无法计算出口令。

❑ **数据完整性：** 比较熟悉的校验算法有奇偶校验和循环冗余校验码（CRC，Cyclic Redundancy Check）校验，这两种校验并没有抗数据篡改的能力，它们一定程度上能检测并纠正数据传输中的信道误码，但却不能防止对数据的恶意破坏。哈希算法“消息摘要”的特性，使它成为目前应用最广泛的一种数据完整性校验和算法。

4. 区块链

- 区块链（英文名：blockchain或block chain）是一种块链式存储、不可篡改、安全可信的去中心化分布式账本，它结合了分布式存储、点对点传输、共识机制、密码学等技术，通过不断增长的数据块链记录交易和信息，确保数据的安全和透明性。
- 区块链起源于比特币（Bitcoin），最初由中本聪（Satoshi Nakamoto）在2008年提出，作为比特币的底层技术。从诞生初期的比特币网络开始，区块链逐渐演化为一项全球性技术，以太坊（Ethereum）等新一代区块链平台的出现进一步扩展了应用领域。

4. 区块链

▣ 区块链包括三个基本要素，即

- **交易**（Transaction，一次操作，导致账本状态的一次改变）、
- **区块**（Block，记录一段时间内发生的交易和状态结果，是对当前账本状态的一次共识）和
- **链**（Chain，由一个个区块按照发生顺序串联而成，是整个状态变化的日志记录）。

▣ 区块链中每个区块保存规定时间段内的数据记录（即交易），并通过密码学的方式构建一条安全可信的链条，形成一个不可篡改、全员共有的分布式账本。

4. 区块链

- ▣ 通俗地说，区块链是一个收录所有历史交易的账本，不同节点之间各持一份，节点间通过共识算法确保所有人的账本最终趋于一致。
- ▣ 区块链的特点包括去中心化、不可篡改、透明、安全和可编程性。
- ▣ 智能合约技术使区块链可编程，支持更广泛的应用。

5. 典型技术

与数据安全、隐私保护相关的术语、概念及内涵。

○ 可信计算

可信计算(Trusted Computing)，是一种基于密码的运算与防护并存的计算机体系安全技术，保证全程可检测可监控。可信计算核心部分是可信根，通常是可信硬件芯片。

可信并不等同于安全，但它是安全的基础，因为安全方案、策略只有运行在未被篡改的环境下才能进一步确保安全目的。通过保证系统和应用的完整性，可以确保使用正确的软件栈，并在软件栈受到攻击发生改变后能及时发现。总的来说，在系统和应用中加入可信验证能够减少由于使用未知或遭到篡改的系统/软件遭到攻击的可能性。

以PC机可信举例，通俗来讲，可信就是在每台PC机启动时检测BIOS和操作系统的完整性和正确性，保障你在使用PC时硬件配置和操作系统没有被篡改过，所有系统的安全措施和设置都不会被绕过；在启动后，对所有的应用，如社交软件、音乐软件、视频软件等应用可进行实时监控，若发现应用被篡改立即采取止损措施。

5. 典型技术

与数据安全、隐私保护相关的术语、概念及内涵。

○ 机密计算

机密计算（Confidential Computing）是通过基于硬件的可信执行环境（TEE，Trusted Execution Environment）对使用中的数据进行保护。

可信执行环境TEE被定义为提供一定级别的数据完整性、数据机密性和代码完整性保证的环境，比如Intel SGX、ARM Trustzone等。

在受信任的硬件执行环境基础上构建安全区域，所有参与方将需要参与运算的明文数据加密传输至该安全区域内并完成运算，安全区域外部的任何非授权的用户和代码都无法获取或者篡改安全区域内的任何数据。机密计算可在可信硬件执行环境内保护数据的隐私，但当数据离开可信硬件执行环境时无能为力。

5. 典型技术

与数据安全、隐私保护相关的术语、概念及内涵。

○ 密文计算

密文计算是指所有参与运算的明文数据使用指定的规则转换为密文，在密文空间中进行特定形式的代数运算并得到结果，密文运算的结果再通过相应的转换规则转换为明文运算结果，该结果与明文运算结果一致。同态加密是密文计算代表性技术。

○ 安全多方计算

安全多方计算能够同时确保输入的隐私性和计算的正确性，在无可信第三方的前提下通过数学理论保证参与计算的各方成员输入信息不暴露，且同时能够获得准确的运算结果。

5. 典型技术

与数据安全、隐私保护相关的术语、概念及内涵。

○ 隐私计算

隐私计算（Privacy compute）是面向隐私信息全生命周期保护的计算理论和方法，是隐私信息的所有权、管理权和使用权分离时隐私度量、隐私泄漏代价、隐私保护与隐私分析复杂性的可计算模型与公理化系统。——李凤华老师：《隐私计算：概念、内涵和实例》

隐私计算（Privacy compute 或 Privacy computing）是指在保护数据本身不对外泄露的前提下实现数据分析计算的技术集合，达到对数据“可用、不可见”的目的。—宽泛认知

将数据加密后，在加密的数据上直接进行运算，然后对运算的结果进行解密，这种计算方式是

- ☐ A 可信计算
- ☐ B 机密计算
- ☐ C 密文计算
- ☐ D 安全多方计算

目 录

「01」

知识点一：法规制度

「02」

知识点二：技术体系

「03」

知识点三：典型案例

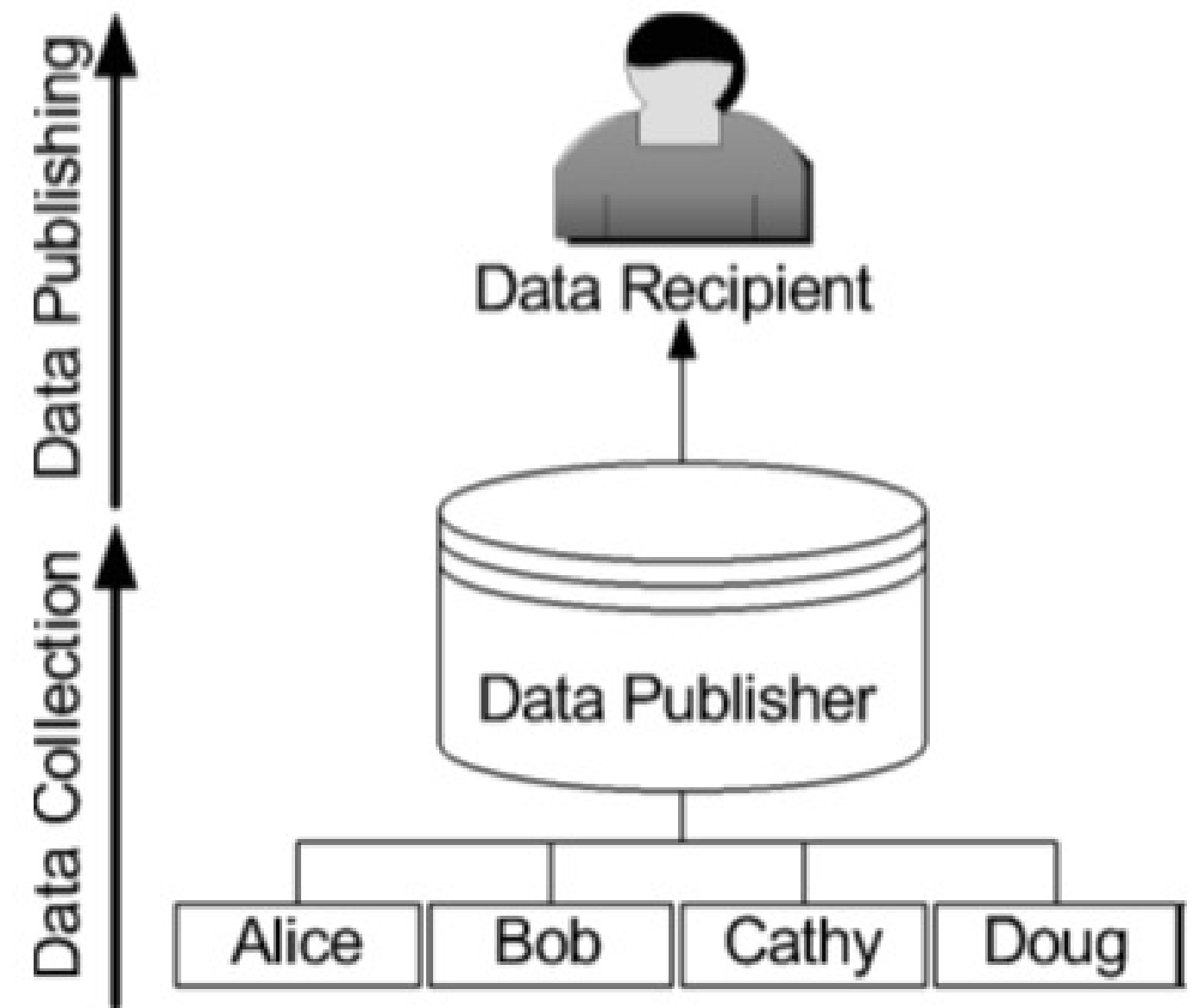
「04」

知识点四：数据胶囊

1. 明文发布

○ 典型案例：精准医疗

一个典型例子就是精准医疗，即利用海量医院病人的数据，提高医疗诊治的准确率。医院已经积累了海量的病人数据，但实际上，在医疗机构要用病人数据进行分析以提升诊断准确率时，医院不敢分享这些数据，因为在分享的过程中，一定会存在泄露病人隐私的风险。



1. 明文发布

隐私保护的数据发布技术

在PPDP最基本的格式中，数据发布者有一个格式表：

D（明确的标识符，准标识符QID，敏感属性，非敏感属性）

前提：部分敏感数据（用户疾病、工资等隐私）必须被保留以用于数据分析

基本匿名方法：隐藏标识和/或者记录主的敏感数据

(a) Patient table					(b) External table				
Name	Job	Sex	Age	Disease	Name	Job	Sex	Age	
	Engineer	Male	35	Hepatitis	Alice	Writer	Female	30	
	Engineer	Male	38	Hepatitis	Bob	Engineer	Male	35	
	Lawyer	Male	38	HIV	Cathy	Writer	Female	30	
	Writer	Female	30	Flu	Doug	Lawyer	Male	38	
	Writer	Female	30	HIV	Emily	Dancer	Female	30	
	Dancer	Female	30	HIV	Fred	Engineer	Male	38	
	Dancer	Female	30	HIV	Gladys	Dancer	Female	30	
					Henry	Lawyer	Male	39	
					Irene	Dancer	Female	32	

安全吗？

1. 记录关联

通过准标识符关联记录泄露隐私。

2. 属性关联

不能通过准标识符关联记录，但可以通过属性集推断的结论来泄露其隐私。

1. 明文发布

K-匿名

K匿名是指公开的数据中包含的个人信息至少 $k-1$ 条不能通过其他个人信息确定出来。也就是公开数据中的任意准标识符QID信息，相同的组合都需要出现至少k次。K匿名可以抵御记录关联和属性关联。

K匿名方法：泛化-模糊准标识符

(下图结果 3-匿名或4-匿名 2-样化)

差分攻击：通过比较公开数据和既有的知识推测出个人隐私。举例，通过公开数据知道4个女艺术家有病，另外一个就是没病了。

(c) 3-anonymous patient table

Job	Sex	Age	Disease
Professional	Male	[35-40)	Hepatitis
Professional	Male	[35-40)	Hepatitis
Professional	Male	[35-40)	HIV
Artist	Female	[30-35)	Flu
Artist	Female	[30-35)	HIV
Artist	Female	[30-35)	HIV
Artist	Female	[30-35)	HIV

(d) 4-anonymous external table

Name	Job	Sex	Age
Alice	Artist	Female	[30-35)
Bob	Professional	Male	[35-40)
Cathy	Artist	Female	[30-35)
Doug	Professional	Male	[35-40)
Emily	Artist	Female	[30-35)
Fred	Professional	Male	[35-40)
Gladys	Artist	Female	[30-35)
Henry	Professional	Male	[35-40)
Irene	Artist	Female	[30-35)

3. 表关联

不能唯一关联记录，但可以通过出现概率实现表之间的关联。可通过差分攻击获得准确隐私。



对Alice而言，在表d中有5条，而在c表中，有4条记录。则Alice得病的概率是4/5

1. 明文发布

差分攻击

patient	cancer
Amy	1
Bob	0
Tom	1
Jack	1

攻击者不知道Jack是否患病，但知道Jack在表中的第四行

Select count(*) from patient where cancer=1 limit 4; → 3

Select count(*) from patient where cancer=1 limit 3; → 2

通过查询结果的变化量来推测
隐私数据 → 1

1. 明文发布

差分隐私

差分隐私

- 差分隐私可以采用拉普拉斯机制实现，拉普拉斯机制通过向返回结果中添加符合拉普拉斯分布的随机噪声来实现差分隐私
- 添加噪声的大小与差分隐私的保护程度由隐私预算参数 ϵ 决定
- 隐私预算越大，噪声范围越小

patient	cancer
Amy	1
Bob	0
Tom	1
Jack	1

攻击者不知道Jack是否患病，但知道Jack在表中的第四行

Select count(*) from patient where cancer=1 limit 4; $\rightarrow 3+x_1$

Select count(*) from patient where cancer=1 limit 3; $\rightarrow 2+x_2$

攻击者无法通过查询结果的变化量来推测隐私数据 $\rightarrow 1+x_1-x_2$

1. 明文发布

差分隐私

重复攻击

- 重复攻击是针对差分隐私的**攻击方式**
- 拉普拉斯机制添加噪声的特点是**均值为0**
- 如果攻击者向数据库请求重复执行同一个查询语句，**将结果求和平均，就有极大的概率获得真实结果**

攻击者攻击成功概率表

ϵ	噪声绝对值的数据分布				多次查询添加噪声的平均值落在危险区间内的概率			
	90%	95%	99%	99.9%	100	1000	10000	10000
1	2.29	2.98	4.50	6.43	100.00	100.00	100.00	100.00
0.1	23.24	29.99	45.51	66.56	25.59	73.75	99.99	100.00
0.01	227.97	296.22	463.48	677.26	2.72	9.12	27.85	73.70

2. 半密文发布

○ 典型案例1：联合精准广告推荐



数据孤岛：用户游戏记录



数据孤岛：用户购买游戏设备记录

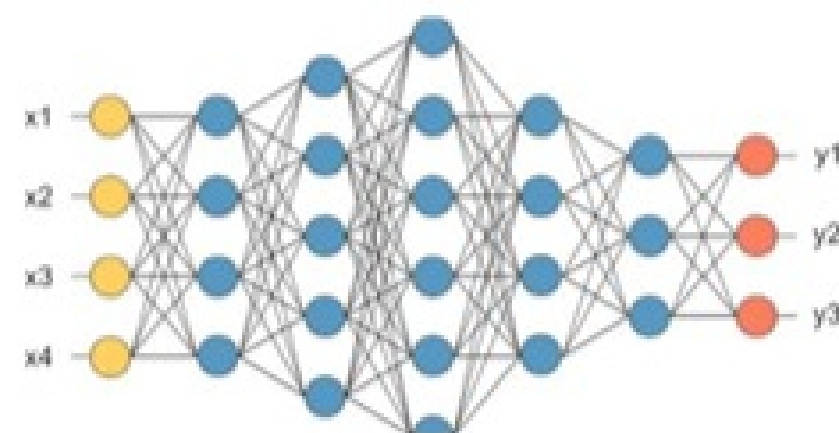
解决方案：密文集合运算（安全多方计算的特例）

2. 半密文发布

○ 典型案例2：联合数据预测与分析



数据资源：有用户财务状况



付费预测可否向会员推荐



大型超市：向会员推广大额商品

解决方案：纵向联邦机器学习（数据对齐采用密文交集运算）

3. 全密文计算

密态数据库



可搜索加密、保序加密
数据库数据加密后的查询问题

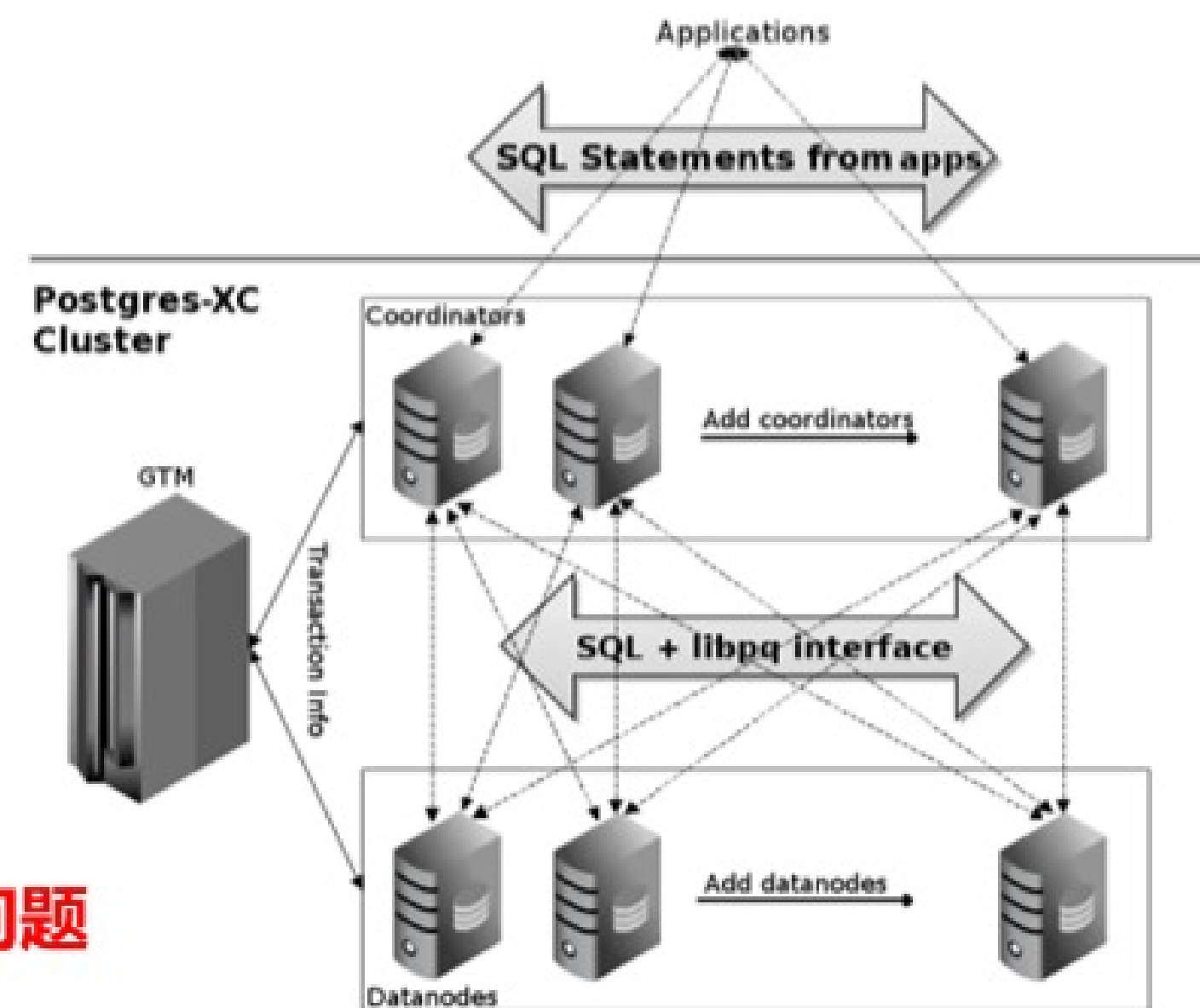


Figure 1: Postgres-XC architecture

目 录

「01」

知识点一：法规制度

「02」

知识点二：技术体系

「03」

知识点三：典型案例

「04」

知识点四：数据胶囊

新概念：数据胶囊

数据胶囊是一种保护隐私的数据交换模型，
包含用户要共享的加密数据以及与之相对应的访问策略。

目前，作为学术论文来说，数据胶囊的理论架构都比较完备

- [Wang19,Wang21]: PRIVPOLICY+PRIVGUARD
- [Gao21]: TEEKAP
- [Unnibhavi22]: IronSafe

新概念：数据胶囊

实践1：数据胶囊管理器PrivGuard

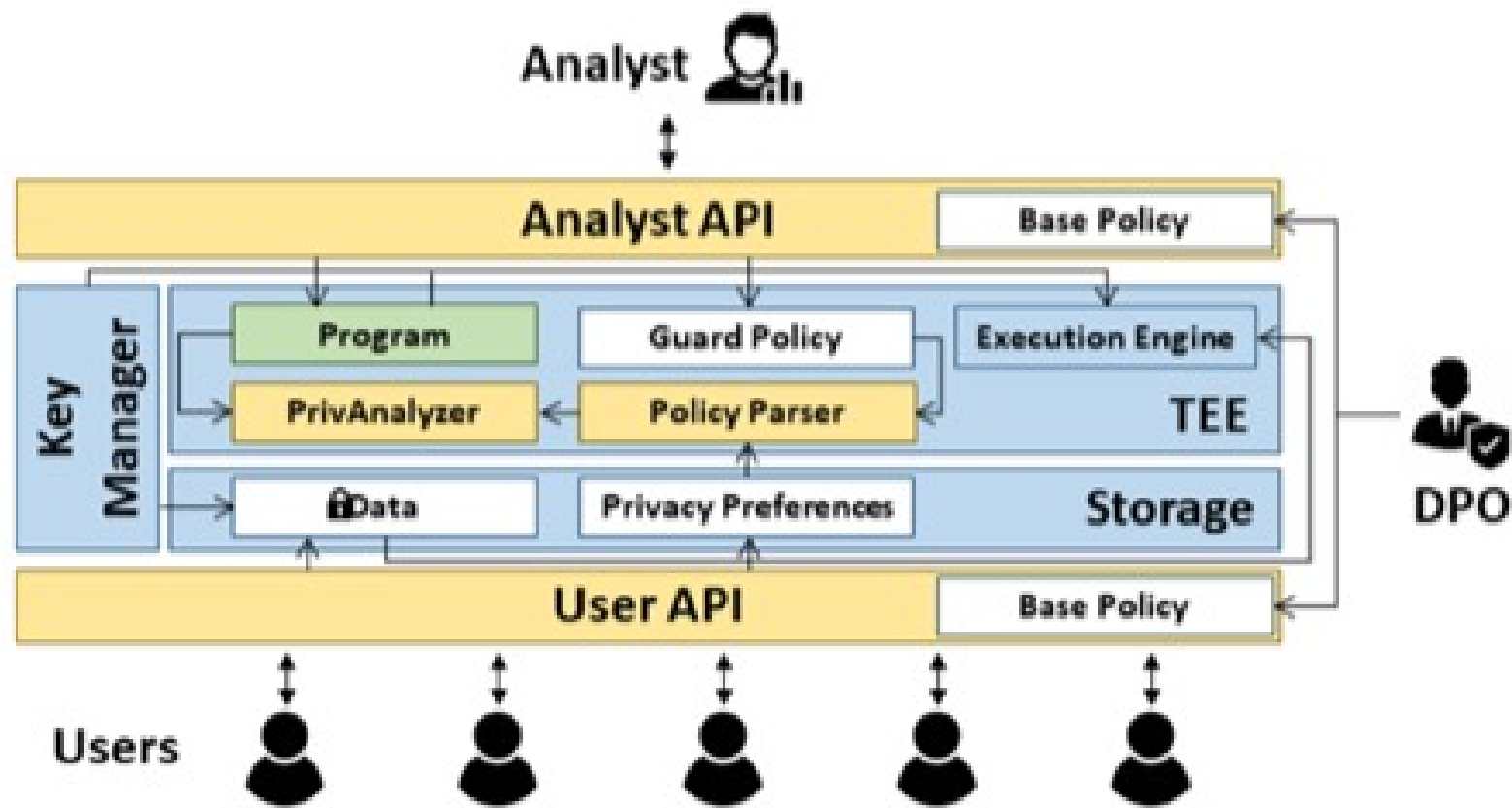


Figure 2: PRIVGUARD prototype infrastructure. White: data/policies; green: analysis programs; blue: off-the-shelf components; yellow: newly-designed components.

- 1.数据保护官员(DPOs)、法律专家和领域专家合作将隐私法规（base policy）转化为机器可读的策略语言。
- 2.在收集数据之前，数据主体将由客户端API进行辅助，以指定他们的隐私偏好。
- 3.数据分析人员提交程序来分析收集到的数据&提交一个相应的不弱于基本政策的保护策略（Guard Policy）。
- 4.提出的静态分析PrivAnalyzer检查分析程序，以确认其符合保护策略（Guard Policy）。同时，加载隐私偏好不大于保护政策的数据子集，进行实际分析。
- 5.根据PrivGuard的输出，结果解密给分析师或继续被保护。

新概念：数据胶囊

实践2：南开&华为的数据库应用的数据胶囊

胶囊构建：指定加密策略+分析程序+访问策略

指定策略：谁能访问？访问次数？

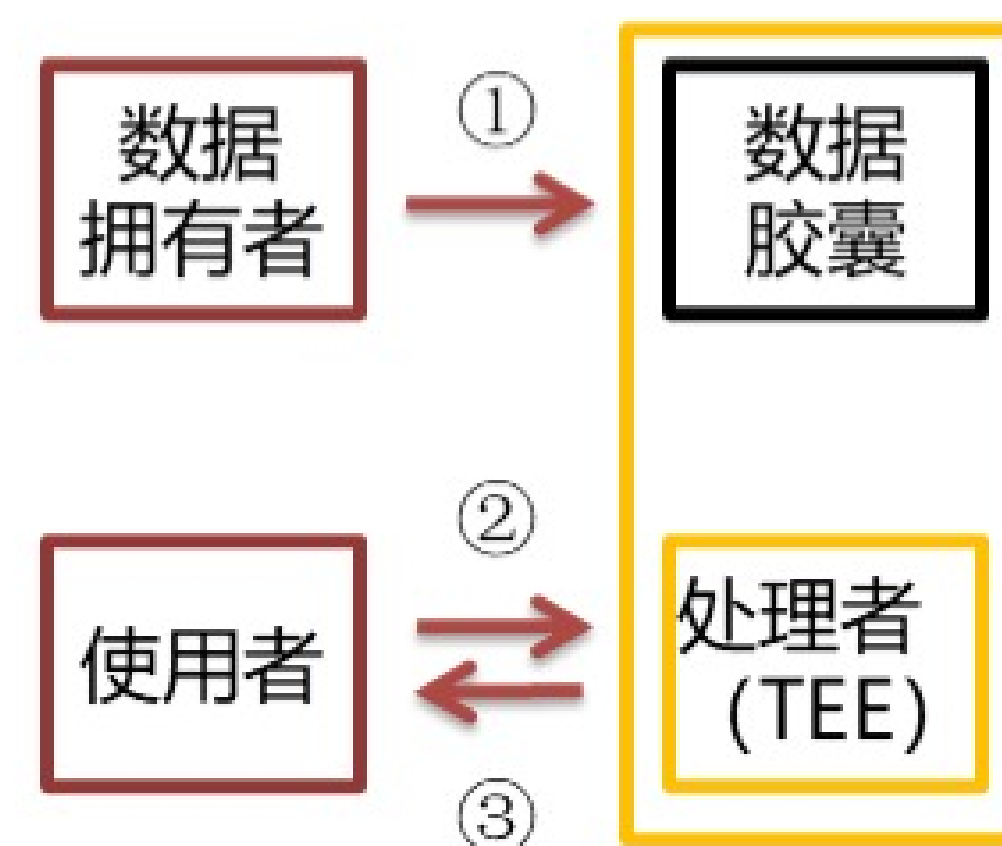
执行环境：TEE或者区块链？

胶囊访问：先策略验证
再执行分析程序
后胶囊自更新

基于属性加密？

零知识证明？

同态签名？



谢 谢

